

Lista de verificação de controles e conformidade

Para concluir a lista de verificação de avaliação de controles, consulte as informações fornecidas em [Relatório sobre escopo, objetivos e avaliação de riscos](#). Para obter mais detalhes sobre cada controle, incluindo o tipo e a finalidade, consulte o [categorias de controle](#) documento.

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys possui esse controle atualmente?*

Lista de verificação para avaliação de controles

Sim	Não	Controlar
☐	☒	Privilégio Mínimo
☒	☐	planos de recuperação de desastres
☒	☐	Políticas de senha
☐	☒	Separação de funções
☒	☐	Firewall
☐	☒	Sistema de detecção de intrusão (IDS)
☐	☒	Cópias de segurança
☒	☐	Software antivírus
☒	☐	Monitoramento, manutenção e intervenção manuais para sistemas legados.
☐	☒	Criptografia
☐	☒	Sistema de gerenciamento de senhas
☒	☐	Fechaduras (escritórios, lojas, armazéns)

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | Vigilância por circuito fechado de televisão (CFTV) |
| ☒ | ☐ | Deteção/prevenção de incêndios (alarme de incêndio, sistema de sprinklers, etc.) |

Para concluir a lista de verificação de conformidade, consulte as informações fornecidas no documento. [Relatório sobre escopo, objetivos e avaliação de risco. Para obter mais detalhes sobre cada regulamentação de conformidade, consulte o \[controles, estruturas e conformidade\]\(#\) leitura.](#)

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys segue atualmente essas boas práticas de conformidade?*

Lista de verificação de conformidade

Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI DSS)

- | Sim | Não | Melhores práticas |
|--------------------------|-------------------------------------|--|
| ☐ | ☒ | Somente usuários autorizados têm acesso às informações de cartão de crédito dos clientes. |
| ☐ | ☒ | As informações do cartão de crédito são armazenadas, aceitas, processadas e transmitidas internamente, em um ambiente seguro. |
| ☐ | ☒ | Implementar procedimentos de criptografia de dados para melhorar a segurança dos pontos de contato e dos dados das transações com cartão de crédito. |
| ☐ | ☒ | Adote políticas seguras de gerenciamento de senhas. |

Regulamento Geral de Proteção de Dados (RGPD)

- | Sim | Não | Melhores práticas |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Os dados dos clientes da UE são mantidos em sigilo e segurança. |

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Existe um plano em vigor para notificar os clientes da UE dentro de 72 horas caso seus dados sejam comprometidos/ocorresse uma violação de segurança. |
| ☒ | ☐ | Garantir que os dados sejam devidamente classificados e inventariados. |
| ☒ | ☐ | Garantir o cumprimento das políticas, procedimentos e processos de privacidade para documentar e manter os dados adequadamente. |

Controles de Sistemas e Organizações (SOC tipo 1, SOC tipo 2)

Sim	Não	Melhores práticas
☐	☒	As políticas de acesso do usuário são estabelecidas.
☐	☒	Dados sensíveis (PII/SPII) são confidenciais/privados.
☒	☐	A integridade dos dados garante que os dados sejam consistentes, completos, precisos e tenham sido validados.
☐	☒	Os dados estão disponíveis apenas para indivíduos autorizados a acessá-los.

Esta seção é opcional e pode ser usado para fornecer um resumo das recomendações ao gerente de TI sobre quais controles e/ou melhores práticas de conformidade a Botium Toys precisa implementar, com base no risco que representam caso não sejam implementados em tempo hábil.

Recomendações (opcional): Nesta seção, forneça recomendações, relacionadas a controles e/ou necessidades de conformidade, que seu gerente de TI possa comunicar às partes interessadas para reduzir os riscos aos ativos e melhorar a postura de segurança da Botium Toys.

Após a revisão das práticas de segurança da empresa Botium Toys, foram identificadas diversas vulnerabilidades que requerem atenção imediata. Com base na Avaliação de Risco, observa-se a ausência de controles essenciais, como o princípio de privilégio mínimo, uso de criptografia, sistema de detecção de intrusões (IDS), plano de recuperação de desastres, rotinas de backup, política de senhas robusta e um sistema centralizado de gerenciamento de credenciais.

Considerando que a empresa realiza transações com clientes globalmente, essas falhas representam riscos significativos. O acesso irrestrito a dados sensíveis aumenta a exposição a ameaças internas. A ausência de criptografia compromete a confidencialidade das transações, facilitando interceptações e vazamentos. A falta de um IDS reduz a capacidade de detecção de incidentes em tempo hábil. Além disso, a inexistência de planos de recuperação e backups coloca a continuidade do negócio em risco em caso de falhas ou ataques. Políticas de senha inadequadas e a ausência de gestão centralizada de credenciais ampliam ainda mais a superfície de ataque.

Como recomendações, sugere-se a implementação imediata do princípio de privilégio mínimo, adoção de criptografia para dados em trânsito e em repouso, implantação de um sistema IDS, criação de um plano de recuperação de desastres e rotinas de backup periódicas. Também é essencial revisar a política de senhas conforme boas práticas atuais e adotar uma solução centralizada para gerenciamento de credenciais.

Apesar das fragilidades identificadas, a empresa demonstra iniciativa ao alinhar-se parcialmente à GDPR e iniciar a implementação do framework NIST CSF. No entanto, é necessário avançar na maturidade de segurança para garantir conformidade e proteção adequada de seus ativos, dados e clientes.